

Zimbabwe Commercial Bank ABC– Controls and Compliance Checklist

Controls Assessment Checklist

Select **Yes** or **No** to indicate whether the bank currently has the control in place.

Yes	No	Control	Explanation
✓		Least Privilege	Currently, many bank employees have access to sensitive customer financial data. Access privileges should be limited based on employee roles to reduce the risk of data breaches and insider threats.
✓		Disaster Recovery Plans	The bank does not currently have a formal disaster recovery or business continuity plan. These plans are necessary to ensure banking operations continue after cyberattacks, system failures, or natural disasters.
✓		Password Policies	Existing password requirements are weak and do not meet modern banking security standards. Weak passwords increase the risk of unauthorized system access.
✓		Separation of Duties	Some management staff handle multiple critical tasks such as approving transactions and managing payroll. Duties should be separated to reduce fraud and unauthorized activities.
✓		Firewall	The bank has a firewall configured with appropriate security rules to block unauthorized traffic and protect the internal network.
✓		Intrusion Detection System (IDS)	The bank currently does not use an IDS. An IDS would help detect suspicious activities and possible cyberattacks in real time.
✓		Backups	Critical banking data is not regularly backed up. Secure backups are needed to recover information after a system failure or ransomware attack.
✓		Antivirus Software	Antivirus software is installed on employee devices and monitored regularly by the IT department to protect against malware and viruses.

Yes	No	Control	Explanation
✓		Manual Monitoring, Maintenance, and Intervention for Legacy Systems	Legacy banking systems are still in use, but maintenance schedules and emergency response procedures are unclear. This increases the risk of vulnerabilities and system failures.
✓		Encryption	Sensitive customer and financial data is not fully encrypted. Encryption is necessary to protect confidential banking information from unauthorized access.
✓		Password Management System	The bank does not currently use a centralized password management system. Employees often rely on manual password resets, which affects productivity and security.
✓		Locks (Bank Offices, Vaults, and Server Rooms)	The bank's offices, vaults, and server rooms are secured with functioning locks and controlled physical access systems.
✓		Closed-Circuit Television (CCTV) Surveillance	CCTV surveillance systems are installed and functioning throughout the bank premises to monitor physical security.
✓		Fire Detection and Prevention Systems	Fire alarms, smoke detectors, and fire suppression systems are installed and operational within the bank facilities.

Compliance Checklist

Payment Card Industry Data Security Standard (PCI DSS)

Yes	No	Best Practice	Explanation
✓		Only authorized users have access to customers' credit card information	Currently, many employees can access internal banking systems and customer financial records, including cardholder information.
✓		Credit card information is accepted, processed,	Customer payment information is not fully encrypted, increasing the risk of unauthorized access.

Yes	No	Best Practice	Explanation
		transmitted, and stored securely	
✓		Implement data encryption procedures	The bank does not currently use strong encryption methods to protect customer financial transactions and stored payment data.
✓		Adopt secure password management policies	Password requirements are weak, and no centralized password management system is in place.

General Data Protection Regulation (GDPR)

Yes	No	Best Practice	Explanation
✓		E.U. customers' data is kept private and secure	Customer financial data is not fully encrypted, which may expose sensitive information to cyber threats.
✓		Data breach notification plan exists within 72 hours	The bank has established procedures to notify affected customers and authorities within 72 hours of a data breach.
✓		Ensure data is properly classified and inventoried	Banking assets and customer data have been identified but are not fully classified according to sensitivity levels.
✓		Enforce privacy policies and procedures	Privacy and data handling policies have been developed and communicated to employees and IT staff.

System and Organization Controls (SOC 1 / SOC 2)

Yes	No	Best Practice	Explanation
✓		User access policies are established	Least privilege and separation of duties controls are not fully implemented. Many employees still have unnecessary access to sensitive banking systems.

Yes	No	Best Practice	Explanation
	✓	Sensitive data (PII/SPII) is confidential and protected	Encryption is not fully implemented to protect personally identifiable information (PII) and sensitive financial data.
✓		Data integrity controls are in place	The IT department has controls to maintain accurate, complete, and consistent banking records.
	✓	Data is only available to authorized users	Sensitive information is currently accessible to more employees than necessary, increasing the risk of misuse or data leaks.

Recommendations

To improve the bank's cybersecurity posture and compliance with financial regulations, the following controls should be implemented:

Recommended Security Controls

- Implement Least Privilege access controls
- Enforce Separation of Duties
- Develop Disaster Recovery and Business Continuity Plans
- Strengthen Password Policies
- Implement Multifactor Authentication (MFA)
- Install an Intrusion Detection System (IDS)
- Encrypt all customer and financial data
- Implement a centralized Password Management System
- Schedule regular maintenance for legacy systems
- Perform regular backups of critical banking data

Recommended Compliance Improvements

The bank should:

- Restrict access to customer financial information
- Fully encrypt payment card and customer banking data

- Properly classify and inventory sensitive assets
 - Regularly review access permissions and compliance policies
 - Conduct employee cybersecurity awareness training
 - Perform regular security audits and compliance assessments
-

Conclusion

The assessment shows that the bank has some important security measures in place, including firewalls, antivirus software, CCTV surveillance, and physical security controls. However, significant weaknesses remain in access control, encryption, disaster recovery, and password management.

Addressing these gaps will help the bank:

- Protect customer financial information
- Reduce cyber risks
- Improve operational resilience
- Maintain compliance with banking and privacy regulations
- Strengthen customer trust and confidence